Attacker | Target | Monitoring

BILICHECK: HARDENING DAN MONITORING TARGET NODE

PBL Kelompok 11 | TEK1314 Keamanan Siber

Checkpoint Minggu ke-9

PERKENALAN ANGGOTA KELOMPOK 11

SOC Engagement: Mengamankan Backend BiliCheck (Alat skrining bilirubin non-invasif).

Konteks: IoT BiliCheck

TEAM LEAD

Raditya Rakha Irianto

NIM: J0404241113

Koordinasi slide, pembagian peran kerja tim, alokasi sumber daya VM, dan jadwal presentasi.

Focus: Project Management

RED TEAM

Nala Arham Rozana

NIM: J0404241077

Riset celah kerentanan target node, penyusunan skenario serangan (S1–S3), dan pengujian penetrasi.

Focus: Penetration Testing

BLUE TEAM

Faiz Aidil Baihaqi

NIM: J0404241023

Hardening Target Node (11 kontrol), konfigurasi UFW, Fail2ban, serta monitoring Security Onion.

Focus: Defense & Hardening

BILICHECK: ASLI → REPLIKA TARGET NODE

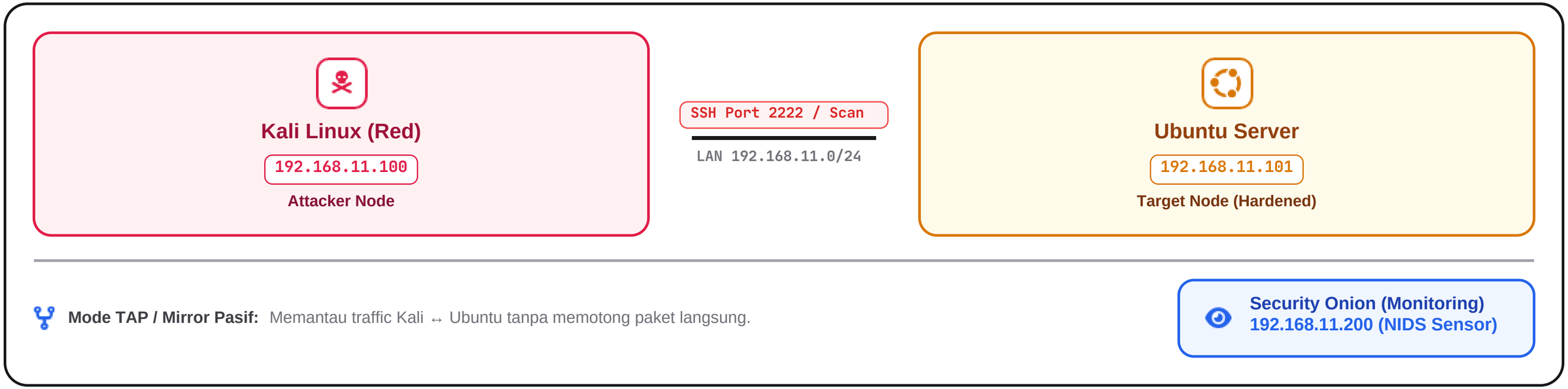
Perbandingan arsitektur IoT BiliCheck di lingkungan produksi vs simulasi target node di lab.

Komponen	Teknologi pada Proyek Asli	Direplikasi Sebagai (Target Node)
Sistem Operasi Backend	Firebase (Cloud) + Ubuntu Server 24.04 (AWS EC2)	**Ubuntu Server 24.04 (VM Lab)**
Database / Penyimpanan	Firebase Firestore & RTDB; CSV di VPS	**Firestore Emulator (127.0.0.1) + CSV Lokal**
Protokol Komunikasi	ESP32 → Firebase Auth/RTDB (HTTPS/REST, SSE)	**HTTP REST (Data dummy → Firestore Emulator)**
Dashboard / Monitoring	Tidak ada di VPS, headless; monitor via Firebase Console	Tidak direplikasi (VPS asli juga headless)

Catatan Arsitektur: Firebase adalah cloud managed service. Security Onion berperan murni sebagai Monitoring Node lab, bukan replika langsung dari komponen IoT.

TOPOLOGI LAB & SKEMA IP

Segmentasi LAN terisolasi 192.168.11.0/24 dengan mekanisme port mirroring pasif ke Security Onion.



> **Catatan Hardening:** SSH standar (port 22) telah diubah ke port **2222** dan firewall UFW menerapkan rule *default deny*. Seluruh aktivitas probing dari node Kali Linux dicatat secara pasif oleh sensor Snort/Suricata di Security Onion.

HARDENING CHECKLIST: TARGET NODE (192.168.11.101)

Status Terverifikasi: 11 dari 11 Kontrol Tuntas Diimplementasikan beserta Bukti Validasi.

11/11 SUDAH
100% SELESAI

A. Access & Auth

3/3 SUDAH

[A1] Nonaktifkan Root SSH

Login root dimatikan; hanya akun sudo yang diizinkan (Bukti A1 ready).

[A2] Ubah Port SSH (22 → 2222)

sshd_config dan ssh.socket disetel ke port 2222 (Bukti A2 ready).

[A3] Fail2ban SSH Protection

Auto-ban IP attacker pada percobaan login berulang (Bukti A3 ready).

Verified

B. Service & Attack Surface

4/4 SUDAH

[B1] UFW Default Deny

Hanya port SSH 2222 yang diizinkan (Bukti B1 ready).

[B2] Firestore Bind 127.0.0.1

Emulator & UI terisolasi lokal, tertutup dari LAN.

[B3] Matikan Layanan Idle

Layanan daemon tidak terpakai dimatikan (Bukti B3).

[B4] Update OS & Node.js

Patch keamanan OS dan dependensi paket ter-update.

Verified

C. Data & Application

4/4 SUDAH

[C1] Non-admin User Ekspor

Proses ekspor berjalan di akun user bilicheck.

[C2] Permisi Folder 700 / File 600

Akses CSV terproteksi ketat hanya untuk pemilik file.

[C3] Cegah Formula Injection

Sanitasi nilai pada export_csv.js bila ada awalan "=".

[C4] Logging & Audit Trail

Catat log gagal ekspor & akses file di audit Ubuntu.

Verified

ATTACK PLAN FASE 2: 3 SKENARIO PENGUJIAN

Rencana pengujian penetrasi terstruktur untuk menguji ketahanan 11 kontrol hardening di Target Node.

ID	Kategori	Target Layanan / Aset	Tools	Mekanisme Deteksi
S1	**Reconnaissance**	Scanning port & service (validasi UFW & port 2222)	`Nmap`	**NIDS (Security Onion alert)**
S2	**Exploitation / Akses**	Brute-force login SSH dummy pada port 2222	`SSH, Hydra`	**NIDS + Fail2ban Auto-block**
S3	**Web/API/Data Injection**	Injeksi formula dummy ("=1+1") saat ekspor data CSV	`SSH, curl, LibreOffice`	**Audit log Node.js & Linux**

Catatan Penting Skenario S3:
Skenario S3 berjalan di dalam sesi SSH yang sah sehingga tidak memicu alarm traffic di NIDS Security Onion. Deteksi dilakukan lewat log proses ekspor Node.js (export_csv.js) dan audit log Linux. Kontrol **C3** dan **C4** memastikan payload formula telah dinetralkan dan percobaan tercatat.

KENDALA & PEMBELAJARAN

Refleksi teknis dan temuan penting selama perancangan arsitektur hingga eksekusi hardening minggu ke-9.

KENDALA

Penyesuaian Tech Stack Cloud ke Lab

Menyesuaikan stack asli Firebase (cloud-managed) ke komponen self-hosted yang dapat diisolasi dan diuji di lab lokal.

Socket Activation SSH Ubuntu 24.04

Pemindahan port ke 2222 memerlukan sinkronisasi ganda antara konfigurasi sshd_config dan systemd ssh.socket.

Klasifikasi Skenario Injeksi Non-Jaringan

Menentukan kategori PBL yang tepat untuk skenario formula injection pada file ekspor CSV lokal.

PEMBELAJARAN

Pemisahan Arsitektur yang Tegas

Pentingnya membedakan secara eksplisit mana komponen yang direplikasi di lab vs yang tetap berada di layanan cloud.

Kombinasi NIDS & Host-Based Logging

Tidak semua ancaman tampak di lalu lintas jaringan; serangan melalui sesi sah harus diimbangi audit log host dan aplikasi.

Sinkronisasi Red–Blue Team Berbasis Checklist

Target hardening tuntas 100% lebih awal karena adanya acuan checklist dan bukti verifikasi before/after yang terstruktur.



TERIMA KASIH

Kelompok 11 · Keamanan Siber · TEK1314

Teknologi Rekayasa Komputer · Sekolah Vokasi IPB University

Raditya Rakha Irianto
NIM: J0404241113 · Lead

Nala Arham Rozana
NIM: J0404241077 · Red Team

Faiz Aidil Baihaqi
NIM: J0404241023 · Blue Team